TP 2.2 – Analyse et correction des vulnérabilités (Linux + Windows)

Objectif

L'objectif de ce TP est de passer d'une phase de **détection des vulnérabilités** à une phase de **correction**, comme cela se fait en entreprise.
Il s'agit d'identifier les failles présentes sur des machines Linux et Windows, d'analyser leurs risques, puis de proposer et appliquer des mesures de sécurisation.

Partie 1 : Analyse des vulnérabilités critiques

Vulnérabilité Linux 1 / Windows – SSL (Sévérité : Haute, CVSS 7.5)

- **Nom :** Mauvaise configuration SSL/TLS
- **Problème :**
  Le service SSL/TLS utilise des paramètres de sécurité faibles ou des protocoles obsolètes.
- **Risque :**
  Les communications peuvent être interceptées ou compromises par un attaquant.
- **Exploitation :**
  Un attaquant peut réaliser :
- des attaques Man-in-the-Middle
- L'interception de données sensibles
- L'exploitation de failles liées aux protocoles SSL/TLS

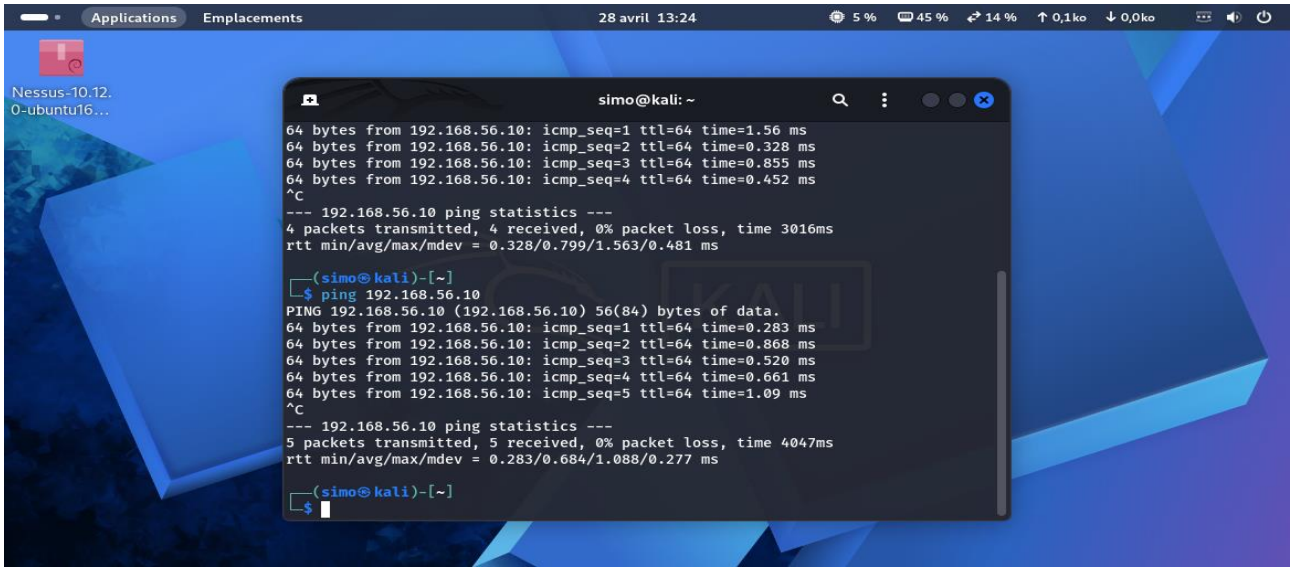
Vulnérabilité Windows – SMB (Sévérité : Moyenne, CVSS 5.3)

- **Nom :** Mauvaise configuration du service SMB
- **Problème :**
  Le protocole SMB présente une configuration insuffisamment sécurisée (ex : signature non requise ou protocoles anciens actifs).

- **Risque :**
  Un attaquant peut accéder aux ressources partagées ou intercepter les communications réseau.
- **Exploitation :**
  Possibilité de :
- Capturer le trafic SMB
- Lancer des attaques réseau
- Exploiter des faiblesses connues du protocole

Vulnérabilité Linux / Windows – ICMP (Sévérité : Faible, CVSS 2.1)

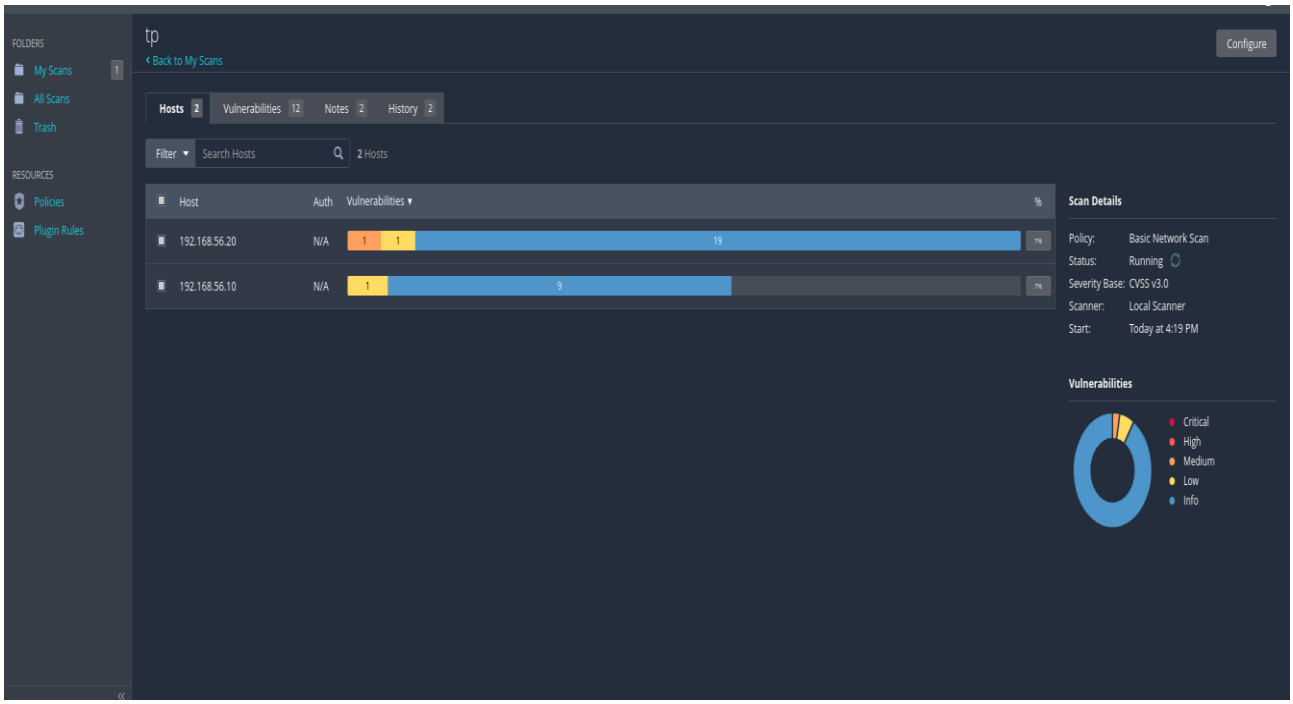
- **Nom :** Réponse ICMP active
- **Problème :**
  Le système répond aux requêtes ICMP (ping).
- **Risque :**
  Facilite la détection de la machine sur le réseau par un attaquant.
- **Exploitation :**
  Utilisé lors de la phase de reconnaissance pour :
- Identifier les machines actives
- Cartographier le réseau



Partie 2 : Correction Linux

Explication des actions

- **Mise à jour du système :**
  Permet de corriger automatiquement les vulnérabilités connues.
- **Désactivation des services inutiles :**
  Réduit la surface d'attaque en limitant les services exposés.
- **Activation du firewall (UFW) :**
  Permet de contrôler les accès réseau et bloquer les connexions non autorisées.



Partie 3: Correction Windows

Commande utilisée

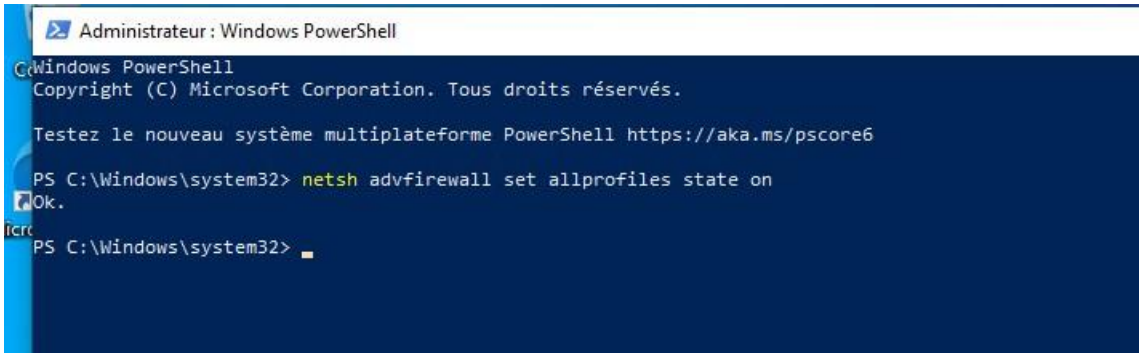
netsh advfirewall set allprofiles state on

Actions réalisées

- Activation du **pare-feu Windows**
- Mise à jour via **Windows Update**
- Désactivation des services inutiles via **services.msc**

Explication

- Le pare-feu protège contre les accès non autorisés
- Les mises à jour corrigent les vulnérabilités
- La réduction des services diminue les points d'entrée pour un attaquant



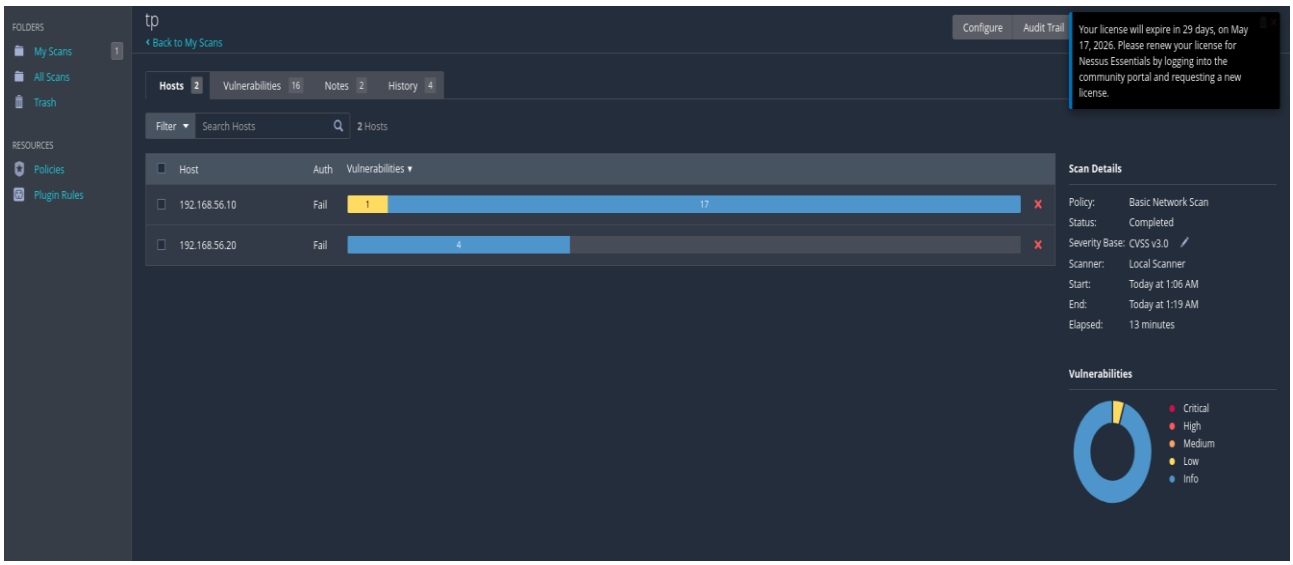
Partie 4 : Re-scan avec Nessus

Objectif

Comparer l'état du système **avant et après correction**

Résultats obtenus

- Diminution du nombre de vulnérabilités
- Réduction des vulnérabilités critiques
- Amélioration du score de sécurité



Conclusion

Ce TP a permis de comprendre que :

- La détection des vulnérabilités est une première étape essentielle
- La correction (hardening) est indispensable pour sécuriser un système
- Les outils comme Nessus permettent une analyse professionnelle des risques

Limites

- Certaines vulnérabilités nécessitent des corrections avancées
- Les résultats dépendent de la configuration des machines
- Un scan ne garantit pas une sécurité totale

Bilan

Ce TP montre clairement qu'en cybersécurité :

- **Détecter une faille ne suffit pas — il faut savoir la corriger efficacement.**